Endpoint detection and response

Description

Endpoint Detection and Response (EDR)

Definizione di EDR

EDR (Endpoint Detection and Response), noto anche come Endpoint Threat Detection and Response (ETDR), è una soluzione di sicurezza per gli endpoint che combina:

- Monitoraggio continuo in tempo reale.
- Raccolta dei dati degli endpoint.
- Analisi automatizzate basate su regole.
- Risposte automatizzate a minacce rilevate.

L'EDR rappresenta una tecnologia emergente che consente il rilevamento e l'analisi delle attività sospette su host ed endpoint, impiegando un alto livello di automazione per rispondere rapidamente alle minacce.

Funzioni principali di un sistema EDR

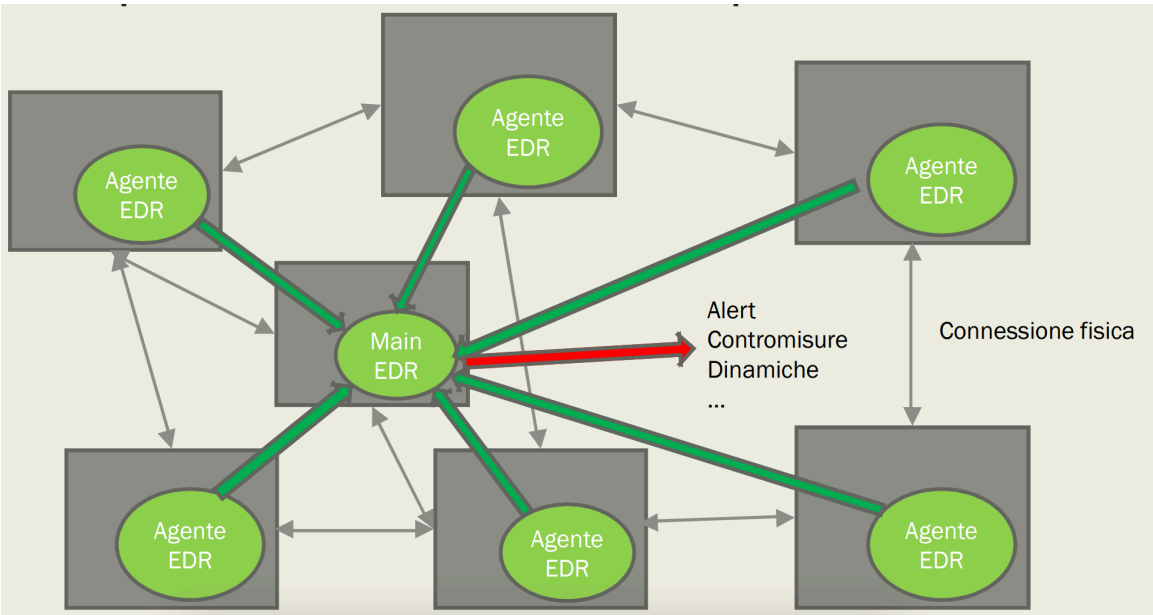
Un sistema EDR svolge le seguenti funzioni:

- **Monitoraggio**: raccoglie dati sulle attività degli endpoint per identificare potenziali minacce.
- **Analisi**: identifica schemi di minaccia e classi di attaccanti attraverso tecniche di analisi avanzate.
- **Risposta automatizzata**: agisce per contenere o eliminare le minacce e avvisa il personale di sicurezza.
- **Forensics e analisi post-attacco**: strumenti per indagare minacce in tempo reale e analizzare attività sospette.

Componenti di un sistema EDR

Un sistema EDR efficace integra tre elementi chiave:

1. **Endpoint Data Collection Agents**
    - Software che monitorano i sistemi e raccolgono informazioni su attacchi e anomalie.
    - Trasmettono dati a un database centrale per l'analisi.
2. **Motore analitico in tempo reale**
    - Analizza i dati raccolti per individuare pattern di minacce note.
    - Attiva risposte automatiche come la disconnessione di utenti o la chiusura di connessioni sospette.
    - Basato su regole contestuali e Indicator of Compromise (IOC).
    - Include tecniche di **Adversary Emulation** per ricostruire intrusioni e comprendere le tattiche degli attaccanti.
3. **Analisi e Forensics**
    - Permette di individuare minacce che non corrispondono a pattern noti.
    - Strumenti di investigazione per analizzare attacchi passati e comprendere l'uso di exploit.
    - Aiuta a identificare minacce persistenti ancora presenti nel sistema.



Differenze tra EDR e Antivirus/Antimalware

- Un sistema **EDR** integra funzionalità avanzate oltre alle capacità di un antivirus tradizionale.
- Un antivirus esegue **scansioni, rilevamenti e rimozione dei virus**, mentre un EDR offre:
  - Monitoraggio avanzato delle attività degli endpoint.
  - Analisi delle minacce in tempo reale.
  - Rilevamento e risposta alle minacce note ed emergenti.
  - Automazione delle risposte di sicurezza.
- Gli antivirus tradizionali non sono più sufficienti a proteggere i moderni perimetri digitali.
- Gli EDR forniscono una protezione più efficace contro attacchi avanzati.

Soluzioni EDR open-source

Esempi di soluzioni EDR open-source includono:

1. **OSSEC**
   - Analizza i log provenienti da più endpoint.

- Rileva malware e rootkit tramite scansioni di processi e file.
- Risposta attiva basata su policy firewall.
- Inventario di sistema: informazioni su hardware, software installato, utilizzo delle risorse, servizi di rete.

2. **TheHiveProject**
   - Dashboard dinamica per la gestione di dati sospetti e malware.
   - Opzioni avanzate di filtraggio e creazione di allarmi personalizzati.
   - Forensics e incident response via web.
   - Analisi incrociata dei report di incidenti con servizi come VirusTotal.

Reagire ad un attacco informatico

Due approcci possibili:

1. **Reazione sul sistema attaccato**: implementare contromisure.
2. **Reazione sul sistema da cui proviene l'attacco**: questa strategia è generalmente da evitare poiché gli attaccanti utilizzano infrastrutture di **command & control** compromesse in precedenza.
   - I nodi di command & control sono sacrificabili per l'attaccante.
   - La soluzione ideale è **smantellare l'infrastruttura degli attaccanti**, il che richiede:
     - **Identificazione dei nodi** dell'infrastruttura nemica.
     - **Eliminazione sincronizzata** di questi nodi.

Questa strategia rientra nella **offensive security** e nel concetto di **defense forward**, ma presenta numerosi problemi:

- **Legali**: attaccare i nodi di un soggetto terzo senza autorizzazione.
- **Tecnici**: necessità di massimizzare l'efficacia e la sincronizzazione degli attacchi.

Il problema dell'attribuzione

Per rispondere in modo offensivo a un'intrusione è essenziale determinare l'origine dell'attacco.

- L'attribuzione è possibile solo tramite **monitoraggio** dell'infrastruttura d'attacco.
- Rivelare il monitoraggio può mettere in allerta gli attaccanti.
- Un metodo alternativo di attribuzione è l'analisi delle **Tactics**, **Techniques**, and **Procedures (TTPs)** utilizzate.
- Confrontare il codice degli exploit con firme note può fornire indicazioni sulla provenienza dell'attacco.

Attribuzione e implicazioni assicurative

- L'attribuzione è fondamentale per determinare chi è responsabile dei danni.
- Le **assicurazioni** non coprono attacchi classificati come **act of war**.
- Se un attacco è sponsorizzato da uno stato, viene considerato un atto di guerra e le assicurazioni non coprono le perdite subite.